

ASSESSMENT TOOL 2 (MEDIUM) – ANSWER SCRIPT

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

Q1. Identifying and Prioritizing Vulnerabilities from Open Ports

Approach

1. Service & version enumeration – run `nmap -sV -sC` against open ports to identify exact service names, versions, and banners (e.g., OpenSSH 7.2, vsftpd 2.3.4).
2. Map to known vulnerabilities – cross-reference each service/version against CVE databases (NVD, Vulners), exploit repositories (searchsploit), and automated scanners (Nessus, OpenVAS).
3. Assess exploitability – check if a public exploit exists, whether authentication is required, and whether it enables RCE, privilege escalation, or information disclosure.
4. Score severity – use CVSS scores to rank each finding (Critical/High/Medium/Low) based on impact and exploitability.
5. Factor in exposure & business context – a critical CVE on an internet-facing production database outweighs the same CVE on an isolated test server.
6. Prioritize – rank using $\text{Risk} = \text{Likelihood} \times \text{Impact}$: unauthenticated RCE and default-credential issues first, then privilege escalation, then information disclosure.
7. Validate manually before reporting – confirm automated findings to eliminate false positives, then document remediation in priority order.

This approach ensures limited remediation time/resources are spent on the vulnerabilities that pose the greatest real-world risk first.

Q2. SYN Scan vs TCP Connect Scan — Differing Results

Why results can differ

- SYN scan sends a SYN and, on receiving SYN-ACK, immediately sends a RST — the handshake is never completed (half-open), so it never reaches the application layer.
- TCP Connect scan completes the full 3-way handshake using the OS's connect() call, so the connection is fully established and visible to the application.
- A stateful firewall or IDS may treat half-open connections differently from fully established ones — dropping/resetting SYN packets while allowing full connections, or vice versa.
- Rate-limiting / SYN-flood protection on the target can silently drop excessive SYN packets, affecting SYN scan results but not necessarily Connect scans.
- Privilege level of the scanning tool — without root/admin rights, nmap silently falls back to a Connect scan even if a SYN scan was requested.
- Load balancers, proxies, or connection-limiting services may respond differently depending on whether a full session is established.

How to verify the findings

- Re-run both scans multiple times and at different times to rule out transient network/rate-limiting effects.
- Cross-check with an independent tool (hping3, masscan) or manual banner grabbing (nc/telnet to the port).
- Capture traffic with Wireshark/tcpdump during the scan to see raw packet-level responses (SYN-ACK, RST, or silence).

- Where authorized, review firewall/IDS logs to confirm whether packets were blocked or reset by a security control.
- Confirm the scanning host has root/admin privileges so the requested scan type is actually being performed.

Q3. Ports Showing as "Filtered"

Likely security mechanisms responsible

- Stateful or stateless firewalls silently dropping packets instead of sending RST/ICMP responses.
- Intrusion Detection/Prevention Systems (IDS/IPS) identifying and blocking scan traffic.
- Router/network ACLs filtering traffic to specific ports or IP ranges.
- Rate-limiting or anti-scanning mechanisms that suppress responses once scan-like behavior is detected.

Additional techniques to gather more information

- **ACK scan (nmap -sA)** — to determine whether a firewall is stateful or stateless and to map firewall rule sets.
- **Packet fragmentation (-f)** — splits probes across packets to evade simple packet-filtering rules.
- **Source port manipulation (--source-port)** — some poorly configured firewalls trust traffic appearing to come from common ports like DNS(53) or HTTP(80).
- **Decoy scanning (-D)** — masks the true source among multiple decoy IPs to reduce detection/blocking.
- **Timing adjustments (-T1/-T2)** — slows the scan to avoid triggering rate-based defenses.

- **Firewalking** — sends packets with incrementing TTLs to map firewall rule boundaries.
- **Scanning from a different vantage point (internal vs external)** — helps distinguish perimeter filtering from host-based filtering.

Q4. TCP vs UDP vs Stealth (SYN) Scanning — Comparison

Aspect	TCP Connect Scan	UDP Scan	Stealth (SYN) Scan
Mechanism	Completes full 3-way TCP handshake (SYN, SYN-ACK, ACK)	Sends UDP packets; relies on ICMP 'port unreachable' for closed ports	Sends SYN, reads SYN-ACK, then RST (handshake never completes)
Privileges	None (uses OS connect() call)	Usually root/admin	Root/admin (raw sockets)
Stealth	Low — logged by app and OS	Moderate — slow, not app-logged	High — rarely reaches app layer
Speed	Slower	Slowest (rate limits, retransmits)	Fast
Best for	Unprivileged scans; verifying results	Enumerating DNS, SNMP, DHCP, NTP	Default general-purpose scanning
Limitations	Easily detected/blocked; slower	Unreliable; ICMP often dropped; very slow	Needs elevated privileges; still detectable

Overall: Use SYN scanning as the default for speed and reduced footprint; use full TCP Connect scanning when raw-socket privileges aren't available or results need independent confirmation; use UDP scanning specifically to enumerate UDP-based services, accepting that it is inherently slower and less reliable.

Q5. Risk Assessment & Mitigation for Exposed SSH, FTP, and Database Ports

Risk assessment steps

1. Confirm exposure and fingerprint each service (banner grabbing / nmap -sV) to identify exact software versions and known CVEs.
2. Check authentication strength — test (with authorization) for default/weak credentials, and whether password-based or key/certificate-based auth is used.
3. Assess encryption in transit — plaintext FTP is a major risk; verify SSH uses strong ciphers/keys; verify database connections require TLS.
4. Evaluate compensating controls — firewall rules, IP allow-listing, VPN/bastion requirement, fail2ban/rate-limiting, and existing monitoring.
5. Determine business impact — classify data sensitivity (e.g., customer/financial data) and criticality of the asset.
6. Calculate risk rating — combine likelihood (ease of exploitation, public exploit availability, internet exposure) with impact (data breach, RCE, disruption) to prioritize.

Recommended mitigation strategies

- **SSH** — disable password authentication in favor of key-based auth, disable root login, change the default port, restrict source IPs via firewall, and keep the service patched.
- **FTP** — replace with SFTP or FTPS to encrypt credentials and data in transit; disable anonymous access; restrict to required IP ranges.
- **Database ports** — never expose directly to the internet; place behind a VPN, bastion host, or application layer; enforce strong authentication and TLS; whitelist specific application servers only.

- **General** — apply the principle of least exposure (close all non-essential ports), segment the network, require VPN/jump-host access for administration, deploy IDS/IPS and continuous monitoring, and schedule regular vulnerability scanning and patching.

Conclusion: Every internet-facing critical service should be treated as high risk by default until verified otherwise — risk is reduced primarily by minimizing exposure (VPN/bastion access), strengthening authentication, and enforcing encryption, backed by continuous monitoring and patching.